SOCIAL ENGINEERING AND PHISHING CAMPAIGN SIMULATION LAB

RISK ASSESSMENT AND MANAGEMENT TECHNIQUES

Laboratory Setup

I ran this entire simulation on my kali Linux virtual machine, so no real people or systems were ever touched. I set up GoPhish on my Kali Linux VM. For sending emails, I used Mailtrap's sandbox SMTP service, which catches test emails instead of actually delivering them, my target group was just one test account I created myself (test@darleneholdings.com), standing in for an employee at a fictional company I named "Darlene Holdings." The phishing landing page was a cloned login page hosted locally at 127.0.0.1, only reachable from inside my own lab machine. At no point did I target real users, use real credentials, or touch any production system.

The Screenshots of the GoPhish campaign results dashboard before click

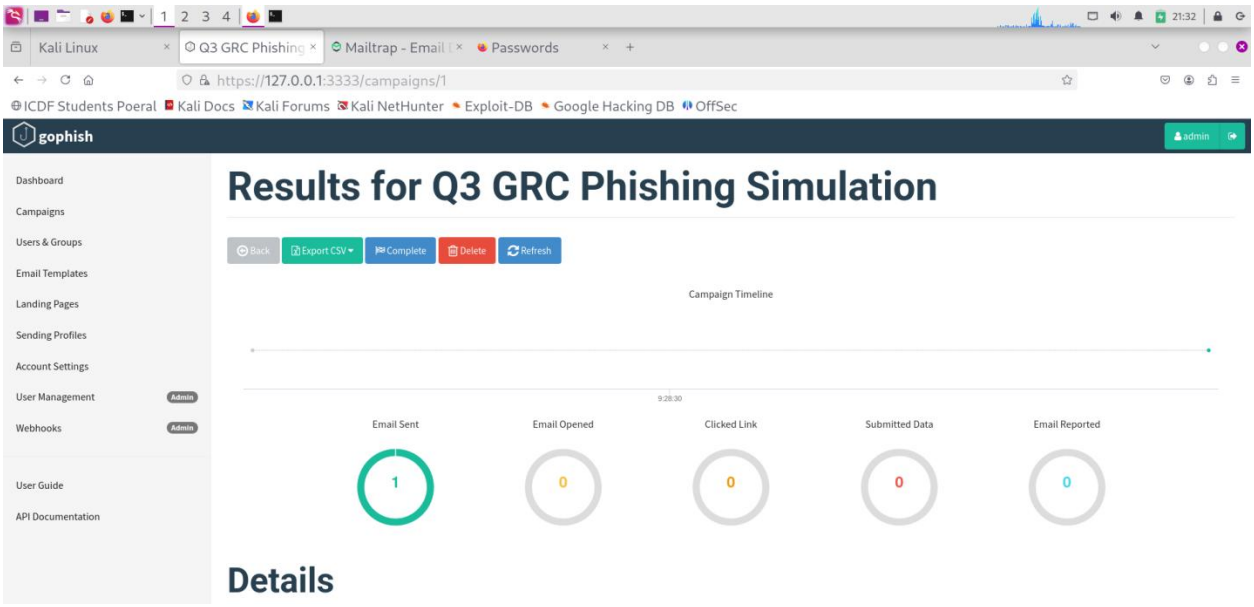


Figure 1.1: The GoPhish campaign results dashboard before click

The Phishing mail sent

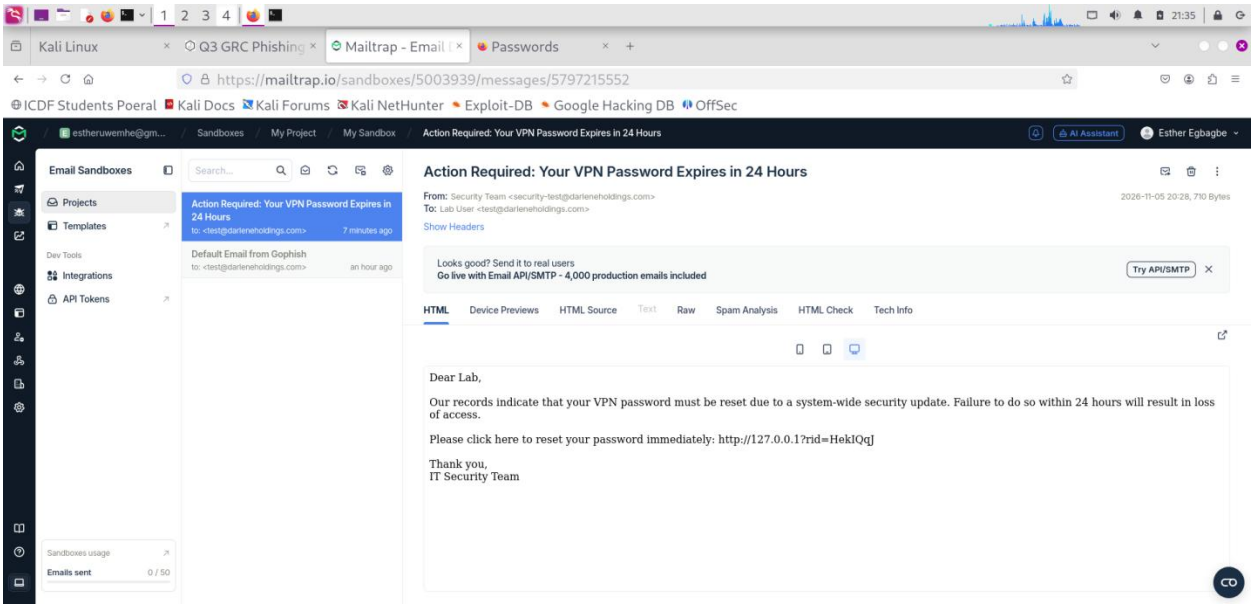


Figure 1.2: The Phishing mail

The Screenshots of the GoPhish campaign results dashboard after click

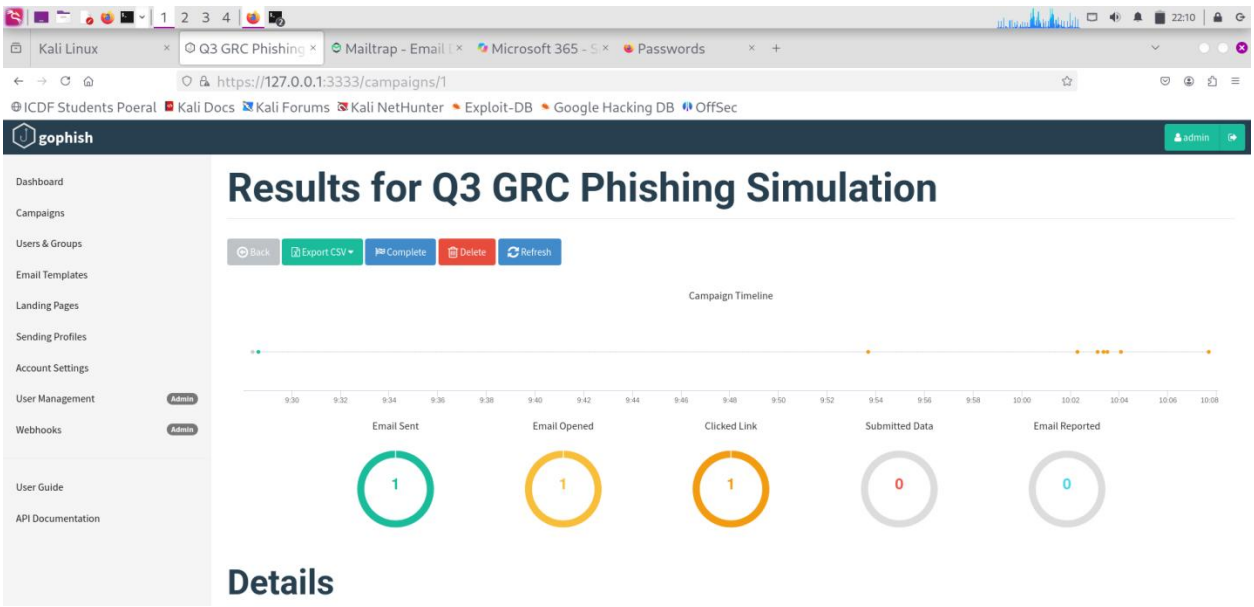


Figure 1.3: The GoPhish campaign results dashboard after click

Triage and Risk Assessment

Metric	Result	Calculated Rate	Risk Interpretation	Control Failure
Emails Opened	1/1	100%	The test user opened the phishing email without first questioning the sender or the urgency of the message	Security Awareness training may not be enough to help employees recognized suspicious emails before opening them.
Links Clicked	1/1	100%	The test user clicked the link without checking where it would lead. This gave access to the cloned login page	There was no evidence of checking the link or verifying its destination before clicking
Credential Submitted	Not Captured	Not Captured	No credentials were captured. However this was due to a technical issue with the cloned Microsoft login page, which redirected to microsoft's real authentication page because of its client-side JavaScript. So, I cannot conclude that the user recognized the phishing attempt	Inconclusive. The issue with the landing page prevented credential capture, so I cannot use this result to assess MFA or credential-handling controls

Drafting the Executive Summary & Recommendations

To: CISO, Head of HR, and Executive Management
From: GRC Audit Team
Date: November 6, 2026
Subject: Result of Q3 Controlled Phishing Simulation and Human Risk Assessment

1. Executive Summary

I carried out a controlled phishing simulation in my own lab environment to see how a user would respond to a simulated phishing email.

Since this was a personal lab project, I used only one test account instead of testing an entire department or organization. This means the results are more of a proof of concept and should not be treated as a representation of how a whole workforce would respond.

From the results, the test user opened the phishing email and clicked the link, giving me a 100% open rate and a 100% click-through rate. This shows how an email designed around urgency can encourage someone to interact with it without first checking if it is legitimate.

2. Key Findings and Metrics

i. Email Open Rate: 100% (1/1) – The subject line, "Action Required: Your VPN Password Expires in 24 Hours", successfully got the test user to open the email.
ii. Link Click-Through Rate: 100% (1/1) – The test user clicked the link without verifying where it would lead or whether it was legitimate.
iii. Credential Submission Rate: Not Captured – I was unable to capture any credentials because the cloned Microsoft login page redirected to Microsoft's real authentication page due to its client-side JavaScript. This was a technical issue with the lab setup, so I cannot conclude that the user recognized the phishing attempt.

3. Risk Analysis

Although this test involved just one account, the results show how easily an urgency-based phishing email can get someone to open a message and click a link without proper verification.

In a real organization, if this behavior occurs across a larger number of employees, it could expose the organization to several risks, including:

a) Unauthorized access: Attackers could gain access to company systems through stolen login credentials.
b) Data breaches: Sensitive company or customer information could be exposed, leading to financial and regulatory consequences.
c) Reputational damage: A successful phishing attack could affect customer trust and expose the organization to data protection issues under regulations such as GDPR and NDPR.

4. Recommended Actions

Based on my findings, I would recommend the following:

a) Implement Multi-Factor Authentication (MFA): MFA should be prioritized as an additional layer of protection, especially because phishing emails can be used to trick users into revealing their login details.
b) Improve Security Awareness Training: Rather than relying only on annual security training, organizations should introduce regular, practical phishing awareness exercises to help employees recognize suspicious emails and links.

c) Include Phishing Simulations in Staff Training: Phishing simulations should be part of employee onboarding and should also be conducted quarterly. Future exercises should involve more participants to provide a better understanding of employee behavior.
d) Review the Acceptable Use Policy (AUP): The policy should clearly explain how employees can identify suspicious emails and the steps to take when they receive or interact with one.

5. Lab Limitations

There were a few limitations during this assessment.

First, I used only one simulated account because the exercise was carried out in my personal lab. As a result, the 100% open and click-through rates cannot be used to represent the behavior of an entire workforce.

Another limitation was the credential capture process. The cloned Microsoft login page redirected to Microsoft's real authentication servers because of its built-in client-side JavaScript. This prevented me from capturing credentials during the test.

For future simulations, I would need to select a landing page that works properly within the isolated lab environment and use a larger test population to get more meaningful results.